ROLES, RESPONSIBILITIES AND AUTHORITIES MATRIX

RACI-001 | Companion governance document to IMF-001

Document ID: RACI-001
Version: 1.0 — DRAFT
Parent Framework: IMF-001 — Information Management Framework
Classification: Internal Use
Owner: Information Security
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Roles, Responsibilities and Authorities Matrix
Document ID	RACI-001
Version	1.0 — DRAFT
Status	Draft for Review
Parent Framework	IMF-001 — Information Management Framework
Document Owner	Information Security
Approved By	[CISO / CIO]
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]
Regulatory Alignment	ISO 27001, GDPR, GxP, 21 CFR Part 11, EU Annex 11, SOX, HIPAA, CCPA
Documents Covered	IMF-001, POL-001 through POL-005, SOP-001, SOP-005 (and all subsequent suite documents)

Revision History

Version	Date	Author	Change Description
0.1	[DATE]	[Author]	Initial draft — covers framework governance, data and system classification, access management, risk, BC/DR, incident response, third party, compliance, and privacy domains
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This document formally defines all roles that participate in the Information Management Framework (IMF) and its subordinate document suite. For each role, it provides a formal definition, the typical title or function that holds the role, the authority level, and the scope of accountability.

It also provides a comprehensive RACI matrix — mapping every key activity and decision across all IMF domains to the roles defined here. The RACI matrix is the single authoritative reference for who does what, who is accountable for what, and who must be consulted or informed in each information management process.

This document is a companion to the IMF — it lives at the same level as the framework, not beneath it in the Policy hierarchy — because it spans the entire suite and is not specific to any single domain or policy.

2. Scope

This RACI covers all activities defined in the following documents currently in the IMF suite, and will be updated as further documents are added:

- IMF-001 — Information Management Framework
- POL-001 — Data Classification Policy
- POL-002 — Data Retention and Disposal Policy
- POL-003 — Data Integrity Policy
- POL-004 — Privacy Policy
- POL-005 — System Classification Policy
- SOP-001 — Data Classification Process
- SOP-002 — Data Retention and Disposal Process
- SOP-003 — Data Integrity Process
- SOP-004 — Privacy Process
- SOP-005 — System Classification Process
- POL-006 — Computer System Validation and Qualification Policy
- POL-007 — Change Management Policy
- POL-008 — Access Control Policy
- POL-009 — Privileged Access Management Policy
- POL-010 — Information Security Risk Policy
- POL-011 — Business Continuity Policy
- POL-012 — Incident Response Policy
- POL-015 — IT Service Management and Operational Incident Policy

- POL-013 — Third Party and Vendor Risk Policy
- POL-014 — Audit Trail and Monitoring Policy
- EXC-001 — Exception Management Policy and Register
- Anticipated future documents: WI-001, WI-005 (see REG-001 for full list)

When a new policy, SOP, or Work Instruction is added to the suite, this document must be reviewed and updated to incorporate any new roles or activities within 30 days of the new document's approval.

3. RACI Legend

The following codes are used throughout the RACI matrix. Each activity has exactly one Accountable (A) role. Multiple Responsible (R), Consulted (C), and Informed (I) roles are permitted.

Code	Meaning	Definition
A	**Accountable**	Owns the outcome. One role per activity maximum. Has authority to approve.
R	**Responsible**	Does the work. Executes the activity. May be multiple roles.
A/R	**Accountable & Responsible**	Single role both owns and executes — typically for owner-led tasks.
C	**Consulted**	Input sought before the activity is complete. Two-way communication.
I	**Informed**	Notified after the activity is complete. One-way communication.

4. Role Definitions

The following roles are formally defined for the purposes of this framework. Where a role is held by a function rather than a named individual, the head of that function is accountable unless otherwise specified.

Role	Typical Title / Function	Authority Level	Accountability Scope	Key Obligations Under IMF
Board / Audit Committee	Non-Executive Directors; Audit & Risk Committee	Ultimate corporate authority. Approves risk appetite.	Enterprise-wide information risk oversight.	Receives periodic information risk reporting from CISO. Approves material changes to risk appetite. Final escalation for material incidents.
Chief Information Officer (CIO)	CIO or equivalent (VP Technology, CTO in some structures)	Executive. Framework Owner.	Accountable for the existence, currency, and effectiveness of the entire IMF suite.	Owns IMF-001. Approves all Policies (POL series). Approves RACI-001. Chairs technology governance. Signs off on policy exceptions.
Chief Information Security Officer (CISO)	CISO or Head of Information Security	Executive / Senior Leadership.	Accountable for the information security control environment across all domains.	Co-chairs ISSG. Approves Tier 1 system classifications. Approves Tier 5 data reclassifications. Leads incident response at material level. Co-approves vendor onboarding for Tier 1 / GxP systems.
Data Protection Officer (DPO)	DPO (statutory role under GDPR where applicable)	Independent advisory authority. Statutory obligations.	Accountable for privacy regulation compliance across all personal data processing.	Advises on Tier 4 (Sensitive Personal) data classification. Approves downward reclassification of Tier 4 data. Leads data subject request fulfilment. Coordinates regulatory breach notification. Conducts DPIAs.
Information Security Steering Group (ISSG)	Cross-functional governance committee — CISO (chair),	Governance committee. Ratifies framework-level	Oversight of the IMF, risk register, and policy compliance across the organisation.	Ratifies IMF changes. Receives quarterly risk register. Escalates material risk items to Board. Reviews policy

Role	Typical Title / Function	Authority Level	Accountability Scope	Key Obligations Under IMF
	CIO, DPO, Compliance, Business Continuity, Legal	decisions.		compliance dashboard. Reviews exception log.
Data Owner	Business unit head, department director, or equivalent senior manager responsible for a defined data domain	Business decision authority over their data domain.	Accountable for the classification, accuracy, appropriate use, and periodic review of all data assets within their domain.	Assigns and confirms data classification tiers. Approves access to data within their domain above standard thresholds. Initiates reclassification where necessary. Annual review sign-off.
System Owner	Business or technical manager with primary responsibility for a specific information system	Decision authority over the system's purpose, users, and data holdings.	Accountable for the classification, lifecycle, controls, and periodic review of their assigned system.	Completes system classification (WI-005). Signs off Asset Register entry. Initiates and approves annual classification review. Accountable for system decommissioning process.
Data Custodian (IT)	IT operations, infrastructure, or application management team	Operational / technical authority within defined IT governance.	Responsible for implementing and maintaining technical controls mandated by data and system classification.	Implements handling controls per data sensitivity tier. Configures system controls per criticality tier. Maintains Asset Register entries. Executes backup, DR, and patching processes.
Information Security (function)	Information Security team, reporting to CISO	Specialist advisory and oversight authority.	Responsible for the operational running of the IMF — classification guidance, adjudication, monitoring, and policy maintenance.	Validates classifications (data and system). Adjudicates disputes. Maintains Document Register (REG-001) and Asset Register. Coordinates annual review cycles. Monitors compliance. Manages exception log.
Compliance / QA	Quality Assurance, Regulatory Affairs, or Compliance	Regulatory specialist authority.	Accountable for GxP data integrity oversight and regulatory compliance	Assigns and validates GxP and regulatory flags. Oversees CSV/CSA programme. Coordinates SOX

Role	Typical Title / Function	Authority Level	Accountability Scope	Key Obligations Under IMF
	function		assurance across all applicable frameworks.	ITGC testing. Supports regulatory inspections. Investigates data integrity incidents.
Business Continuity (BCP)	Business Continuity Manager or IT Resilience function	Specialist authority for resilience and recovery planning.	Accountable for the organisation's DR strategy, BC plans, and recovery testing programme.	Confirms RPO/RTO achievability for Tier 1 and Tier 2 systems. Plans and executes DR tests. Maintains BC plans. Coordinates crisis communications.
IT / Infrastructure	IT infrastructure, cloud operations, or DevOps function	Technical operational authority.	Responsible for the technical architecture, availability, and operational performance of all information systems.	Co-completes Input B (functional criticality) with System Owners. Implements tier-required architecture and monitoring. Executes patching and backup. Provides input to vendor technical assessments.
All Personnel	All employees, contractors, and consultants	Individual responsibility.	Responsible for handling information in accordance with its classification and applicable policies, and for reporting suspected breaches or misclassification.	Apply classification labels to data they create. Handle data per its tier. Report suspected misclassification, incidents, or non-compliance to Information Security immediately.

5. Governance of this Document

5.1 Update Triggers

This document must be reviewed and updated whenever any of the following occur:

- A new document is added to the IMF suite (within 30 days of approval)
- A new role is identified in any IMF suite document
- An existing role definition changes materially (e.g., scope, authority, or reporting line)
- An organisational restructure affects any named role
- The annual IMF review cycle identifies gaps or inaccuracies

5.2 Update Process

Updates to this document are owned by Information Security and must be approved by the CIO before the updated version is issued. For minor updates (adding a new activity row to the RACI, correcting a role title), a lightweight review by the CISO and CIO is sufficient. For changes to role definitions or authority levels, ISSG ratification is required.

5.3 RACI Rules

- Every activity in the RACI matrix must have exactly one Accountable (A) role.
- The Accountable role must have the organisational authority to own the outcome — it should not sit below the level at which the decision is made.
- A role may be both Accountable and Responsible (A/R) for an activity, but this should be minimised to avoid lack of independent oversight.
- Consulted (C) and Informed (I) roles are optional but should be included wherever there is a genuine dependency or notification obligation.
- Where a role column is blank for an activity, that role has no defined obligation for that activity.

6. Related Documents

Document ID	Title	Relationship
IMF-001	Information Management Framework	Parent framework — Section 6 introduces the governance model that this document formally defines
REG-001	IMF Document Register	Lists all suite documents; RACI-001 is updated when REG-001 adds new documents
POL-001	Data Classification Policy	Roles in Sections 6 defined and RACI'd here
POL-005	System Classification Policy	Roles in Section 8 defined and RACI'd here
SOP-001	Data Classification Process	Role assignments per step defined and RACI'd here
SOP-005	System Classification Process	Role assignments per step defined and RACI'd here

Section 7. RACI Matrix

Read across each row: A = Accountable · R = Responsible · A/R = Accountable & Responsible · C = Consulted · I = Informed · blank = not involved

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
1. Framework Governance												
IMF annual review — initiate and coordinate					A				R			
IMF annual review — approve and ratify changes	I	A	C	C	R				C	C		
Policy suite — initiate review cycle			A		I				R	I		
Policy suite — review and approve individual policies		A	R	C	I	C			C	C		
ISSG — chair and facilitate quarterly meetings			A						R			
ISSG — attend and participate		C	R	R						R	R	
Board / Audit Committee reporting on information risk	A	I	R	I					C			
Document Register (REG-001) — maintain and update									R			
Framework exception approval		A	C						R			
2. Data Classification (POL-001 / SOP-001)												
New data asset — trigger classification												R
New data asset — complete WI-001 questionnaire												R
New data asset — confirm / override classification tier						A			I			
Tier 4 (Sensitive Personal) — notify and consult DPO				C		A			I			
Tier 5 (Highly Confidential) —			C			A			R			

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
notify InfoSec for confirmation												
Apply classification label to asset						C		R	I			
Implement handling controls per tier						C		R	I			
Register asset in Corporate Asset Register						C		R	I			
Annual classification review — coordinate									R			
Annual classification review — confirm or trigger reclassification						A			I			
Downward reclassification — Tier 4 approval				A		R			C			
Downward reclassification — Tier 5 approval			A			R			C			
Classification dispute — adjudicate									R			
Classification dispute — final determination (escalation)			A						C			
2a. Data Retention and Disposal (POL-002 / SOP-002)												
Assign retention period at point of classification						A		R	I			
Implement automated deletion / archival schedules								R	I			
Trigger legal hold — issue written notice									I	A		
Legal hold — suspend deletion schedules in affected systems								R	I	C		
Legal hold — maintain register and conduct quarterly reviews										A		

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
Legal hold — issue release notice when hold lifted									I	A		
Disposal — execute at end of retention period						C		R	I			
Disposal certificate — produce and retain								R	I	C		
Third-party disposal vendor — approve									A			
Retention schedule — annual review and update					I				R	A		
GxP record retention compliance — oversee									I	A		
2b. Data Integrity — ALCOA+ (POL-003 / SOP-003)												
Data integrity programme — own and manage									I	A		
Data Integrity Risk Assessment (DIRA) — conduct						C	R	C	C	A		
DIRA — QA review and approve										A		
Audit trail configuration — enable and protect in GxP systems							R	R	C	A		
Audit trail — periodic review and anomaly escalation									C	A		
Data integrity training — design and deploy									C	A		
Data integrity training — complete (GxP personnel)										I		R
Data integrity incident — report										I		R
Data integrity incident — triage and investigate (Critical/High)			C						C	A		

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
Data integrity CAPA — approve and track to closure									I	A		
Quarterly data integrity summary — report to ISSG					A					R		
3. System Classification (POL-005 / SOP-005)												
New system — initiate classification process							A		I			
Input A (data-derived) — complete assessment							A		I			
Input B (functional criticality) — complete assessment jointly							A	R	I			
Regulatory flags — assign (GxP, SOX, HIPAA, GDPR)				C			A		C	R		
Final classification — reconcile and document							A	C	R			
Tier 2 / Tier 3 classification — approve							C		A			
Tier 1 classification — approve (co-sign)			A				C		R			
Controls implementation — verify and sign off							C	R	A			
DR strategy for Tier 1 / Tier 2 — confirm achievability							C	C	I		A	
Register system in Corporate Asset Register							C	R	A			
Annual system review — coordinate									R			
Annual system review — confirm or reclassify							A	C	I			
System decommission — approve and record							A	R	I			

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
Classification dispute — final determination			A						R			
3b. CSV / CSA & Change Management (POL-006 / POL-007)												
New system — determine assurance track (A/B/C/D)							A		R	C		
Track A — approve Validation Plan before lifecycle begins							C		I	A		
Track A — author URS and risk assessment							A	C		R		
Track A — execute IQ / OQ / PQ or CSA testing							C	R		A		
Track A — issue formal release decision for GxP use							C			A		
Track A — maintain Validation Master File							A	R		C		
Track B — maintain SOX ITGC evidence package							A	R	I	C		
Track C/D — sign off structured qualification / acceptance testing							A	C	R			
Change request — raise and document impact assessment							A	R		C		
Change request — technical review (Track A/B/C)							C	C	A			
Change request — validation impact assessment (Track A)							C			A		
CAB — chair and coordinate									A			
CAB — approve Normal Change (Track A/B/C)							C		A	C		
Emergency change — approve before implementation			A						R			

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
Change — post-implementation verification							A	R	C			
Standard Change catalogue — maintain and review									A			
System decommissioning — validation closure report (Track A)							C	R		A		
4. Access & Identity Management (POL-008 / POL-009)												
Access provisioning — request and justify												R
Access provisioning — approve (standard)						A	R		I			
Access provisioning — approve (Tier 1 / GxP — confirm DI training)						A	R		I	C		
Access provisioning — implement								R	I			
MFA enforcement — configure and maintain								R	A			
RBAC role definitions — maintain						A	R		C			
Quarterly access review (Tier 1 / GxP / SOX systems)						A	R		R			
Semi-annual access review (Tier 2 systems)						A	R		R			
Annual access review (Tier 3–4 systems)						A	R		I			
Joiner / mover / leaver — notify Information Security							C					R
Offboarding — revoke access by end of last working day								R	A			

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
Segregation of duties — define and enforce			A			C		R	R			
Privileged Account Inventory — maintain									A			
Privileged access — approve (JIT request)			A						R			
Privileged access — monthly review (Tier 1 / GxP / SOX)			A						R			
PAM platform — manage and monitor									A			
Service account inventory — review quarterly						A	R		R			
Break-glass access — authorise use			A						I			
Break-glass access — credentials rotate post-use									A			
Third-party privileged session — supervise (Tier 1 / GxP)						A	C		R			
5. Information Risk Management (POL-010)												
Annual Information Security Risk Assessment (ISRA) — coordinate									A			
System-level risk assessment — conduct (Tier 1/2 and GxP pre-go-live)						A	C	C	R	C		
Risk Register — maintain and update									A			
Risk Register — quarterly review (all open risks)					A		C		R	C		
Risk treatment plan — own and drive (as Risk Owner)						A	C	C	R	C		

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
Risk treatment — approve (Critical / High risks)		C	A		I				R			
Risk acceptance — sign off (GxP category risks)			A						C	A		
Vulnerability management — scan and triage									A			
Critical vulnerability — emergency patch authorise			A					R	R	C		
Risk reporting to ISSG — quarterly summary					A				R			
Risk reporting to Board / Audit Committee — annual	A	I	R						C			
DIRA Register ↔ IS Risk Register — confirm alignment quarterly									R	A		
6. Business Continuity & Disaster Recovery (POL-011)												
Business Impact Analysis — conduct and maintain						C	C	C	I		A	
BCP/DRP — author (Tier 1 / GxP systems)		C				C	C	R	I	C	A	
BCP/DRP — approve (Tier 1)		A	A				C		C		R	
DR infrastructure — implement and maintain								R	I		A	
Backup configuration and monitoring — own								R	I		A	
Backup restoration test — quarterly (Tier 1/2)								R	I		A	
GxP system DR — validate recovery procedure in OQ						C		R	I	A	C	
DR test — full failover (Tier 1, annual)		C				C	C	R	I	C	A	

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
DR test — tabletop exercise (Tier 2, annual)						C	C	R	I		A	
DR test — document, report gaps, remediate		C					C	R	I		A	
BC/DR activation decision (major incident)		A	C						C		R	
GxP validated state — confirm after DR event								R	I	A	C	
7. Incident Response (POL-012)												
Security incident — detect and report (all staff obligation)												R
Incident — log and assign Incident ID									A			
Incident — triage and severity classify									A			
Incident Commander — declare and lead response									A			
Forensic evidence — preserve before remediation			C						A			
Containment actions — execute (technical)								R	A			
GxP incident — lead domain response and DIRA update						C		R	C	A		
GxP system — confirm validated state before regulated restart								R	C	A		
Personal data breach — assess and notify DPO			R	A					R			
GDPR 72-hour supervisory authority notification			C	A					R	C		
HIPAA breach notification — manage				A					R	C		

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
GxP regulatory notification — assess and send			C						C	A		
BC/DR activation — trigger when RTO breached		C	A						R		C	
Post-incident review — conduct (P1 within 5 days)									A			
Post-incident Risk Register update (POL-010, 30 days)			A						R			
Incident — escalate to Board if material	A	I	R	I								
7b. IT Service Management & Operational Incidents (POL-015)												
Operational incident — detect and report to Service Desk												R
Operational incident — log, classify, and assign								R	I		A	
Major Incident (P1) — declare and command		C							I		A	
P1 on GxP system — notify Compliance / QA within 30 min								R	I	A	C	
GxP system — validate state and sign off restart								R	I	A	C	
VMF — document operational incident record									I	A		
Problem Record — create and own RCA						A	C	R	I		C	
Permanent fix — submit POL-007 change request						A		R	I			
ITSM trend data — report to ISSG quarterly		C			A						R	
BC/DR activation — trigger from operational P1		A	C						C		R	

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
8. Third Party & Vendor Management (POL-013)												
Vendor engagement — initiate risk assessment before contract							C		A	C		
Vendor risk tier — assign and document							C		A	C		
Tier A vendor assessment — conduct and approve		C	C			C	C		A	C		
Tier B/C vendor assessment — conduct and approve							C		A			
GxP vendor qualification — conduct and enter in VMF							C		R	A		
DPA — negotiate, execute, and maintain			C	A			C		R	C		
BAA (HIPAA) — negotiate and execute			C	A					R	C		
Technical Agreement (GxP) — negotiate and execute			C			C			R	A		
Vendor privileged access — approve and supervise (POL-009)									A	C		
International data transfer mechanism — assess and execute			C	A					R	C		
Annual vendor review — conduct and report to ISSG		C					C		A	C		
Vendor breach notification — receive and escalate to IR									A	C		
Vendor offboarding — access revocation and data destruction			C	C		C	C	R	A	C		
9. Audit Trail, Monitoring & Compliance (POL-014 / POL-003 / POL-006)												

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
Audit trail configuration — specify requirements in URS						C			C	A		
Audit trail immutability — implement technical controls								R	I	A		
Audit trail capability — validate in OQ (GxP systems)						C		R	I	A		
SIEM — deploy, configure, and maintain								R	A			
SIEM alert rules — define and maintain								R	A			
Continuous monitoring alerts — investigate									A			
GxP audit trail review — conduct periodically (SOP-003)									C	A		
SOX ITGC audit trail review — conduct quarterly									C	A		
Privileged access audit trail review — conduct monthly (Tier 1)									A			
NTP synchronisation — monitor and maintain								R	A			
Audit trail gap — investigate and treat as potential incident									C	A		
CSV / CSA — oversee and approve validation plans							C	C	I	A		
CSV / CSA — execute validation and document evidence							C	R	I	A		
SOX ITGC testing — coordinate and execute					A				C			
Internal audit — facilitate		C	C	C			C	C	R	A		

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
Regulatory inspection — coordinate response		C	C	C			C	C	R	A		
11. Exception Management (EXC-001)												
Exception request — submit with risk assessment and remediation plan						A	C	C	C	C		
Exception — conduct independent risk assessment									A			
GxP exception — review and assess validated state impact						C			C	A		
Privacy exception — assess GDPR/HIPAA regulatory gap			C	A					C			
Medium exception — approve (risk score 5–9)									A			
High exception — approve (risk score 10–14)		A	C			C			R			
Critical exception — approve and notify Board	A	A	C			C			R			
Exception Register — maintain and update									A			
Exception — confirm compensating controls implemented									A			
Exception Register — review at ISSG quarterly		C	C			C			A			
Exception — close on compliance confirmed						C			A	C		
10. Privacy (POL-004 / SOP-004)												
ROPA — own and maintain				A								
New processing activity — register in ROPA before				A		R						

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
commencing												
DPIA screening — conduct for new processing activities				A		R			C			
DPIA — conduct full assessment				A		R			C			
DPIA — supervisory authority consultation (high residual risk)				A								
Lawful basis — document for each processing activity				A		R						
DPIA (Data Protection Impact Assessment) — conduct				A		R			C			
Data subject request — receive and triage				A					C			
Data subject request — fulfil				A		R		R	C			
Cross-border transfer — confirm mechanism and approve				A		R			C			
Transfer Impact Assessment (TIA) — conduct				A		R			C			
Privacy notice — review and approve		C		A					C			
Special Category data — confirm Art. 9 condition before processing				A		R						
Personal data breach — report to DPO immediately				I					I			R
Personal data breach — assess and notify supervisory authority (72hr)			C	A					R			
Personal data breach — notify affected data subjects (high risk)				A					R			

Activity / Decision	Board	CIO	CISO	DPO	ISSG	Data Owner	Sys Owner	IT / Cust.	Info Sec	Comp / QA	BCP	All Staff
HIPAA breach — notify HHS Secretary				A					R			
DPA / BAA with third-party processors — negotiate and execute			C	A		C			C			
Annual processor review — coordinate and conduct				A		R			C			
Privacy training — annual completion				I								R
ROPA — annual review and update				A		R						

— End of RACI Matrix —

RACI-001 v1.0 DRAFT | [Company Name] | CONFIDENTIAL